Event Information:

EventID :
60
Event Time :
Feb, 14, 2021, 01:05 PM
Rule :
SOC127 - SQL Injection Detected
Level :
Security Analyst
Source Address :
172.16.20.5
Source Hostname :
PentestMachine
Destination Address :
172.16.20.4
Destination Hostname :
gitServer
Username :
kali
Request URL :
https://172.16.20.4/?id=1 and (1,2,3,4) = (SELECT * from db.users UNION SELECT 1,2,3,4 LIMIT 1)
User Agent :
Penetration Test - Do not Contain
Device Action :
Allowed

Analysis Steps:

The claims of this being a pen test visible in the alert immediately stand out but this must be verified. As such emails were searched, filtered to the relevant time-frame.



Result: **5 Mails**

Date	Sender	Recipients	Subject	Final Action
Mar, 07, 2021, 05:31 PM	katharine@letsdefend.io	katharine.isabell@yandex.ru	Blank	Unknown
Mar, 07, 2021, 04:45 PM	aaronluo@cmail.carleton.ca	nicolas@letsdefend.io	Invoice	Unknown
Feb, 14, 2021, 03:00 AM	hahaha@ihackedyourcomputer.com	mark@letsdefend.io	I hacked your computer	Unknown
Feb, 07, 2021, 04:24 AM	john@letsdefend.io	susie@letsdefend.io	Meeting	Unknown
Jan, 31, 2021, 03:48 PM	accounting@cmail.carleton.ca	richard@letsdefend.io	Invoice	Unknown

But no email could be found stating penetration testing activities are to be conducted and as such it must be taken into consideration that this could be an attacker posing as performing legitimate Red Team activities.

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a False Positive which requires escalation and additional verification.

Report:

Incident Summary

Analysis confirms a False Positive alert regarding a SQL injection attempt, paired with a mandatory escalation for verification. The internal host PentestMachine targeted the internal gitServer with a clear SQL injection payload. While the hostname and custom User Agent indicate internal penetration testing, no explicit email authorisation was found during the investigation. The incident is classified as a False Positive to avoid disrupting legitimate operations, but it is being escalated to definitively rule out an attacker masquerading as the Red Team.

Incident Details

- **Alert Name:** SOC127 - SQL Injection Detected
- **Source Host:** PentestMachine (172[.]16.20.5)
- **Target Host:** gitServer (172[.]16.20.4)
- **User Account:** kali
- **Device Action:** Allowed

Analysis and Evidence

- **Activity Breakdown:** On Feb 14, 2021, at 01:05 PM, the source host initiated a web request to hxxps://172[.]16.20.4/?id=1 and (1,2,3,4) = (SELECT * from db.users UNION SELECT 1,2,3,4 LIMIT 1).
- **Payload Identification:** The URL parameters contain a definitive SQL injection payload attempting to extract information from the db.users database table.
- **Evasion / Masquerading Potential:** The web request utilised a custom User Agent reading Penetration Test - Do not Contain. While this flag strongly suggests legitimate internal staff activity, an external threat actor could easily spoof this User Agent to evade containment.

Threat Intelligence

- **Internal Correlation:** A review of email communications yielded five results for the relevant time-frame.
- **Missing Authorisation:** None of the located emails contained explicit authorisation or scheduling for a penetration test.

Actions Taken

1. Analysed the web request to identify the SQL injection payload and the associated source and destination hosts.
2. Reviewed email logs to find official authorisation for the penetration test, which yielded no results.
3. Determined that it must be taken into consideration that this could be an attacker posing as legitimate Red Team operations.
4. Declared the alert a False Positive to prevent unnecessary disruption to potential internal testing but escalated for additional verification.

Let’s Defend Result

